

Отчёт по лабораторной работе №3

Команда реагирования и анализ инцидента безопасности

А. Атанесов, А. Пониц, В. Ефремова, А. Касьянов, Б. Тогтохжаф, Д.

Содержание

1	Цель работы	5
2	Задание	6
3	Теоретическое введение	7
4	Выполнение лабораторной работы	8
4.1	1. Первичное детектирование	8
4.2	2. Анализ событий безопасности на узле CMS	12
4.3	3. Доказательства компрометации CMS и сетевые артефакты . . .	16
4.4	4. Устранение уязвимостей и укрепление	18
5	Выводы	20

Список иллюстраций

Список таблиц

1 Цель работы

Познакомиться с процессом реагирования на инцидент информационной безопасности, научиться анализировать события в логах, выявлять вредоносную активность и применять меры по устранению уязвимостей.

2 Задание

1. Провести анализ логов системы на предмет признаков компрометации.
2. Определить источник инцидента и зафиксировать последовательность действий злоумышленника.
3. Разработать и применить меры реагирования для изоляции заражённой системы и устранения уязвимости.
4. Подготовить отчёт о ходе реагирования.

3 Теоретическое введение

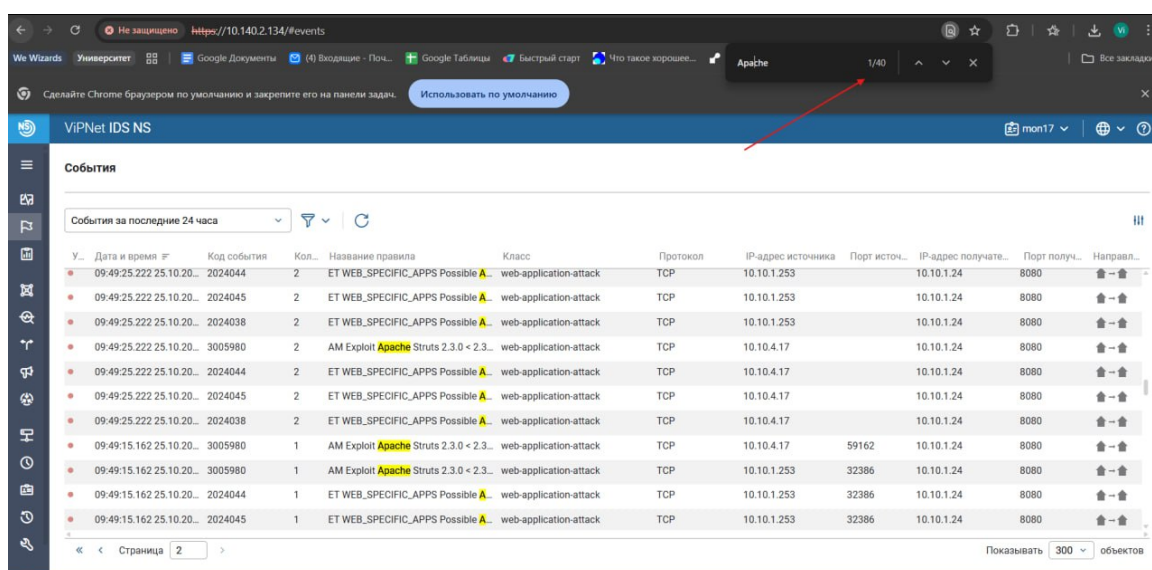
Команда реагирования на инциденты (Incident Response Team) выполняет задачи по обнаружению, анализу, локализации и устранению последствий инцидентов информационной безопасности. Основные этапы реагирования включают:

- Обнаружение и регистрация инцидента;
- Анализ логов и системных событий;
- Изоляция скомпрометированных узлов;
- Устранение уязвимости и восстановление системы;
- Документирование инцидента.

В Windows-журналах безопасности ключевыми являются события: 4624 (успешный вход), 4672 (выдача «особых» привилегий новой сессии), 4688 (создание процесса), 7045 (создание службы).

4 Выполнение лабораторной работы

4.1 1. Первичное детектирование



The screenshot shows the ViPNet IDS NS web interface. The browser's tab bar at the top has a tab labeled 'Apache' with a red arrow pointing to it. The main content area displays a table of events under the heading 'События'. The table has columns for time, event ID, rule name, class, protocol, source IP, source port, destination IP, destination port, and direction. The events listed are related to Apache Struts2 exploitation attempts.

У...	Дата и время	Ид	Код события	Кол...	Название правила	Класс	Протокол	IP-адрес источника	Порт источ...	IP-адрес получате...	Порт получ...	Направл...
•	09:49:25.222 25.10.20...	2024044	2	2	ET WEB_SPECIFIC_APPS Possible	web-application-attack	TCP	10.10.1.253		10.10.1.24	8080	→
•	09:49:25.222 25.10.20...	2024045	2	2	ET WEB_SPECIFIC_APPS Possible	web-application-attack	TCP	10.10.1.253		10.10.1.24	8080	→
•	09:49:25.222 25.10.20...	2024038	2	2	ET WEB_SPECIFIC_APPS Possible	web-application-attack	TCP	10.10.1.253		10.10.1.24	8080	→
•	09:49:25.222 25.10.20...	3005980	2	2	AM Exploit Apache Struts 2.3.0 < 2.3...	web-application-attack	TCP	10.10.4.17		10.10.1.24	8080	→
•	09:49:25.222 25.10.20...	2024044	2	2	ET WEB_SPECIFIC_APPS Possible	web-application-attack	TCP	10.10.4.17		10.10.1.24	8080	→
•	09:49:25.222 25.10.20...	2024045	2	2	ET WEB_SPECIFIC_APPS Possible	web-application-attack	TCP	10.10.4.17		10.10.1.24	8080	→
•	09:49:25.222 25.10.20...	2024038	2	2	ET WEB_SPECIFIC_APPS Possible	web-application-attack	TCP	10.10.4.17		10.10.1.24	8080	→
•	09:49:15.162 25.10.20...	3005980	1	1	AM Exploit Apache Struts 2.3.0 < 2.3...	web-application-attack	TCP	10.10.4.17	59162	10.10.1.24	8080	→
•	09:49:15.162 25.10.20...	3005980	1	1	AM Exploit Apache Struts 2.3.0 < 2.3...	web-application-attack	TCP	10.10.1.253	32386	10.10.1.24	8080	→
•	09:49:15.162 25.10.20...	2024044	1	1	ET WEB_SPECIFIC_APPS Possible	web-application-attack	TCP	10.10.1.253	32386	10.10.1.24	8080	→
•	09:49:15.162 25.10.20...	2024045	1	1	ET WEB_SPECIFIC_APPS Possible	web-application-attack	TCP	10.10.1.253	32386	10.10.1.24	8080	→

Рисунок 1 — ViPNet IDS NS: события по эксплуатации Apache Struts2 (10.10.1.24:8080). Название правила: *AM Exploit Apache Struts 2.3.0 < 2.3.x*, класс: *web-application-attack*. Ключевые связи: 10.10.1.253 → 10.10.1.24:8080; также активность от 10.10.1.47. Вывод: IDS фиксирует эксплуатацию Struts2 на веб-портале.

Методы реализации угроз:	Эксплуатация уязвимости
Метод обнаружения:	Сигнатурный
Симптомы:	Срабатывание средств защиты
Идентификатор инцидента:	380da80c-aa26-48b2-b477-989c0b8f4325
Описание:	Зафиксирована эксплуатация уязвимости CVE-2017-5638. Вероятна компрометация системы с дальнейшим развитием атаки. Уязвимость CVE-2017-5638: Уязвимость парсера Jakarta Multipart программной платформы Apache Struts. Эксплуатация уязвимости может позволить нарушителю, действующему удалённо, выполнить произвольные команды с помощью измененного значения #cmd= string в специально сформированном заголовке HTTP-заголовка (Content-Type)
Рекомендации:	

Рисунок 2 — ViPNet

TIAS: карточка инцидента по CVE-2017-5638 (Jakarta Multipart), метод обнаружения — сигнатурный. Описание указывает на RCE через заголовок Content-Type (инъекция #cmd).

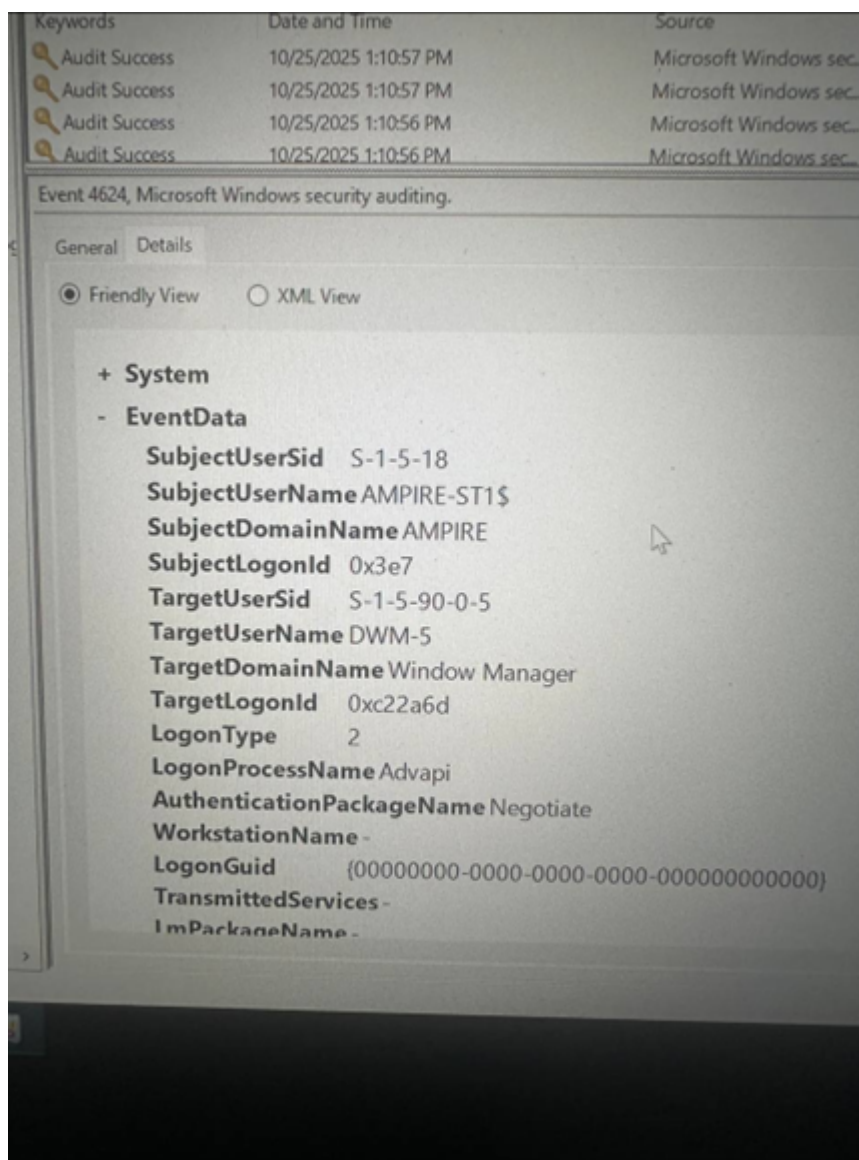
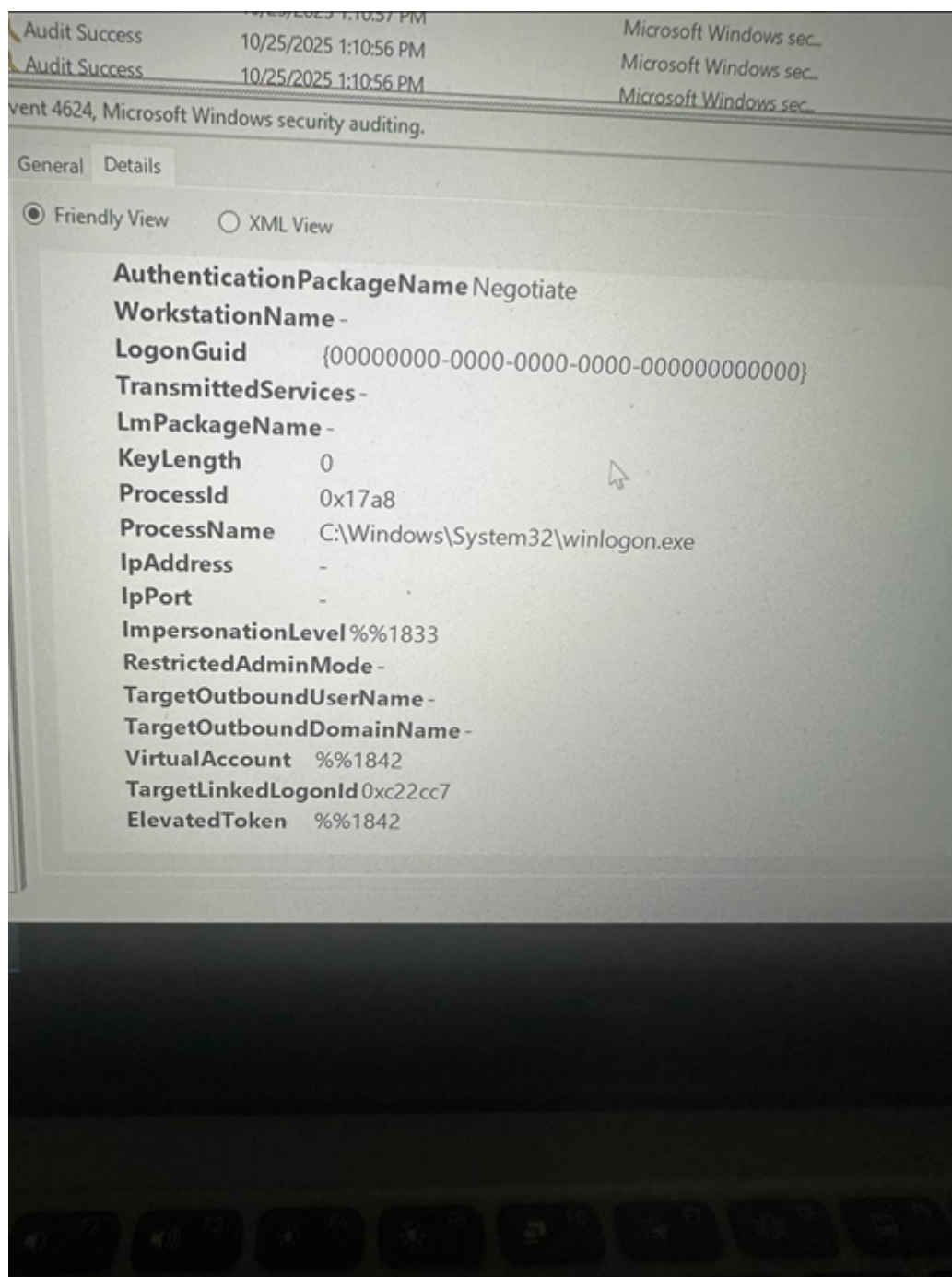


Рисунок 3 —

ViPNet TIAS: рекомендации. Предписано провести аудит и установить последние обновления системного и прикладного ПО.



Рису-

нок 4 — ViPNet TIAS: добавление/актуализация инцидента. Источник: внешний узел 195.239.174.95 (Web Server PHP). Поражённые активы: 10.10.1.24 (Apache Tomcat), 10.10.2.16 (CMS Made Simple). IOC: связь с внешним C2 (зашифрованный туннель).

4.2 2. Анализ событий безопасности на узле CMS

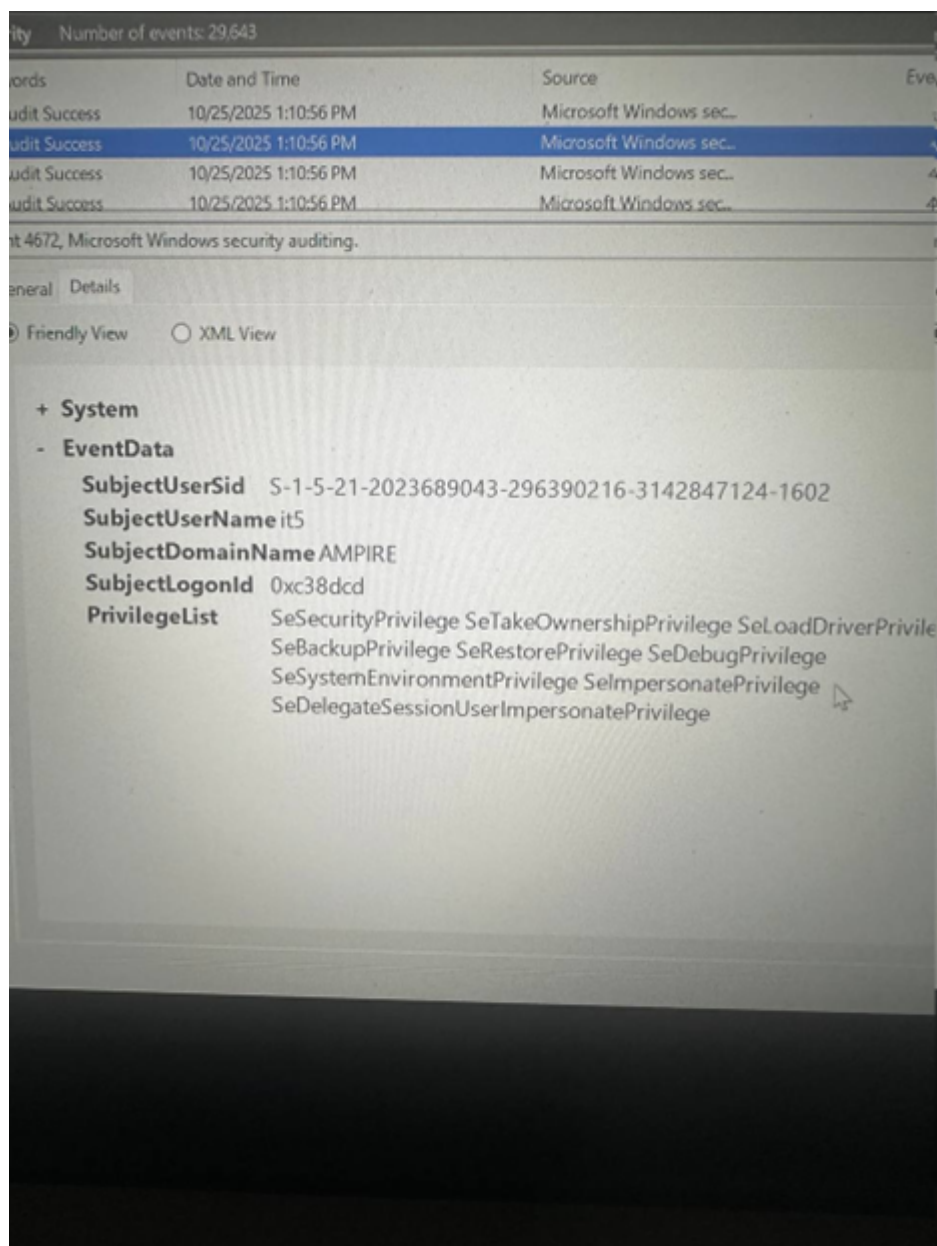


Рисунок 5 —

Event 4624: успешный вход (LogonType=2), процесс winlogon.exe.

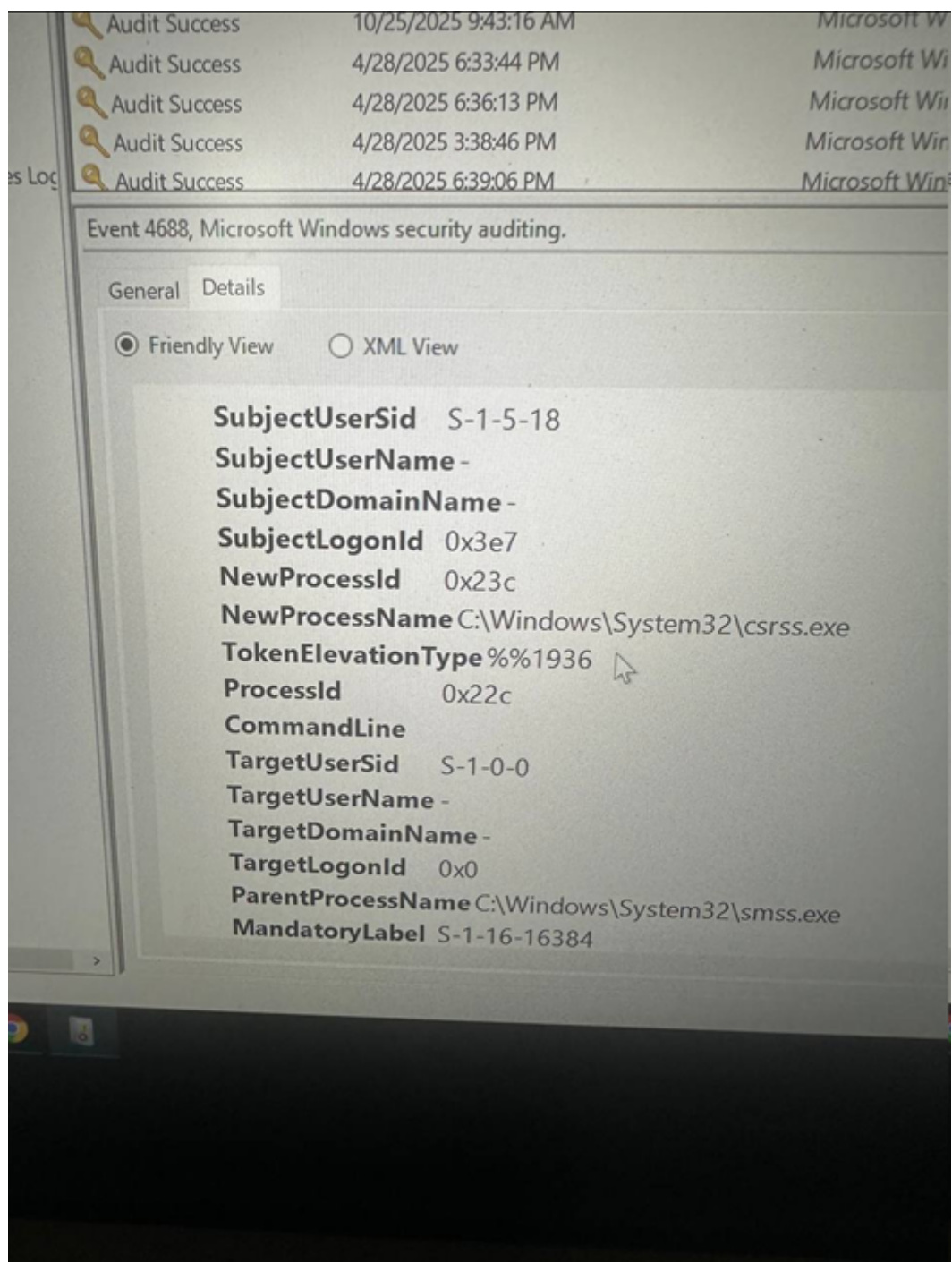


Рисунок 6 — Event 4672: Special privileges assigned to new logon (учётная запись it5). Назначены привилегии: SeDebug, SeImpersonate, SeLoadDriver, SeTakeOwnership и др. Признак высокопривилегированной сессии.

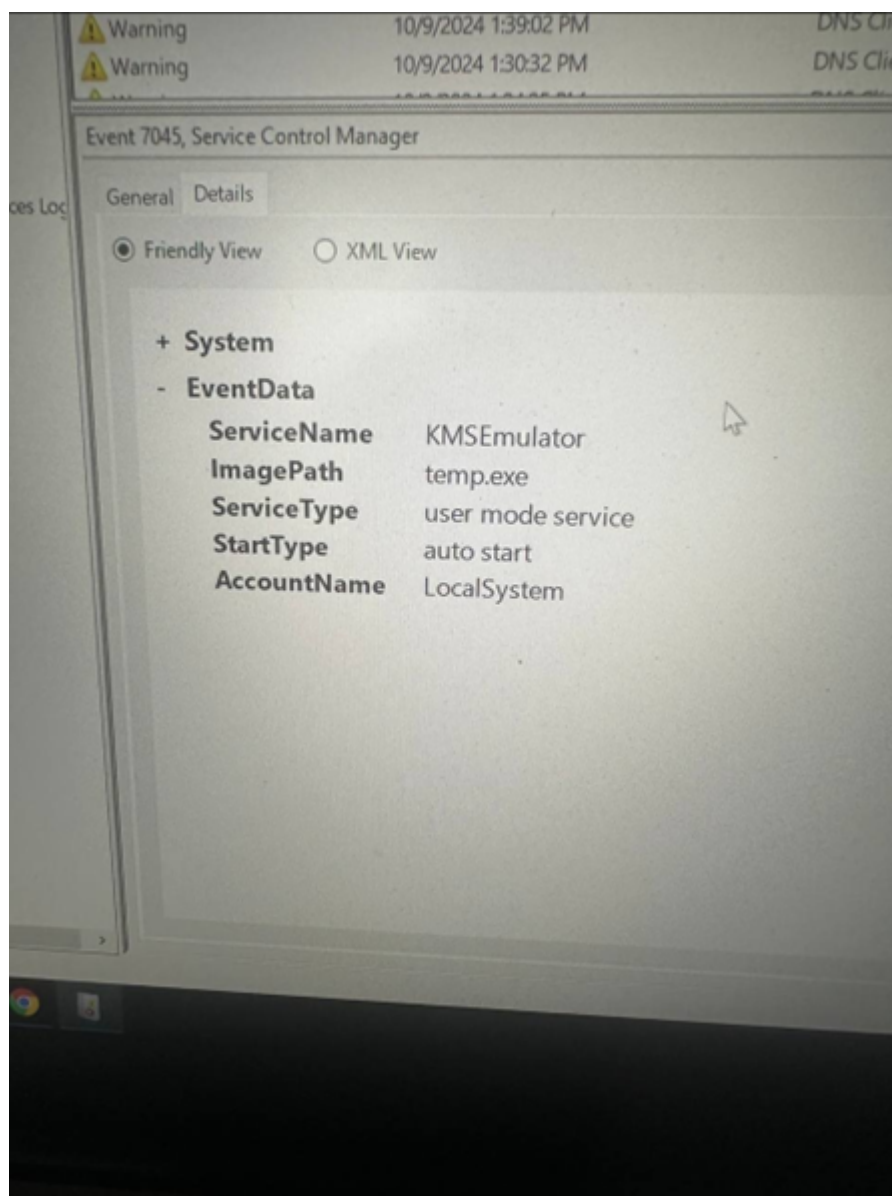


Рисунок 7 —

Event 4688: создан процесс csrss.exe (родитель smss.exe). Подтверждает включённый аудит цепочек Parent/Child.

```
C:\Users\it8>certutil -hashfile C:\Windows\Temp\mSwx1.exe MD5
CertUtil: -hashfile command FAILED: 0x80070002 (WIN32: 2 ERROR_FILE_NOT_FOUND)
CertUtil: The system cannot find the file specified.

C:\Users\it8>cd .

C:\Users\it8>cd :C
The filename, directory name, or volume label syntax is incorrect.

C:\Users\it8>cd C:
C:\Users\it8

C:\Users\it8>cd C:
C:\Users\it8

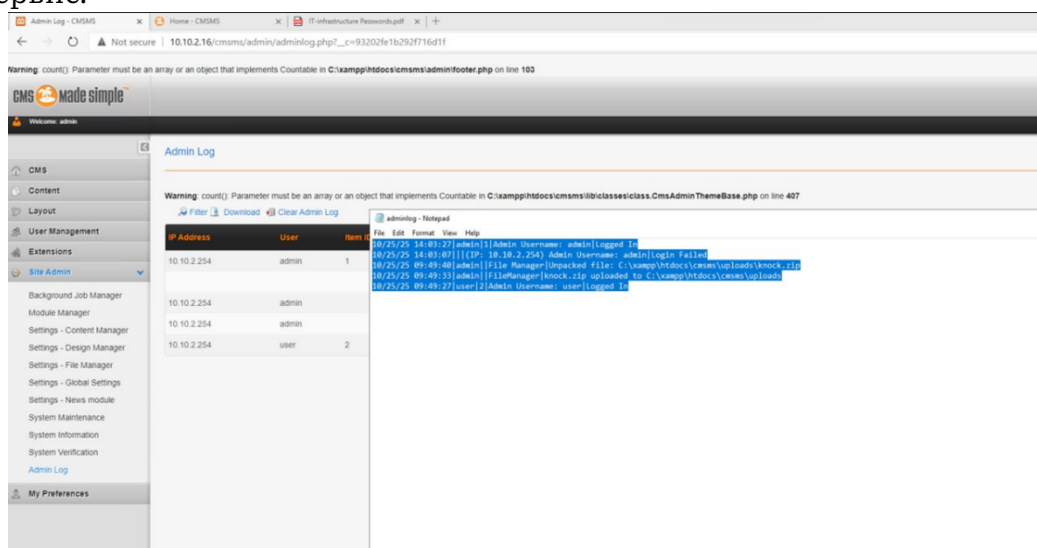
C:\Users\it8>dir C:\Windows\Temp\mSwx1.exe
Volume in drive C has no label.
Volume Serial Number is 9C86-7909

Directory of C:\Windows\Temp

File Not Found

C:\Users\it8>
```

Рисунок 8 — Event 7045: создана служба KMSEmulator, ImagePath = temp.exe, StartType = auto, Account = LocalSystem. Признак персистентности через сервис.



Рису-

нок 9 — CLI: проверка индикаторного файла C:\Windows\Temp\mSwx1.exe — отсутствует (ERROR_FILE_NOT_FOUND, dir → *File Not Found*).

4.3 3. Доказательства компрометации CMS и сетевые артефакты

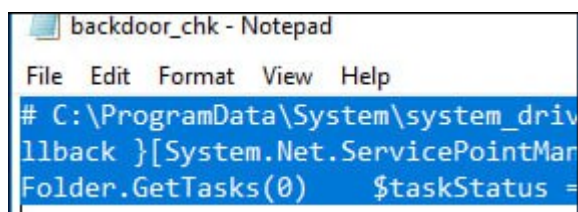
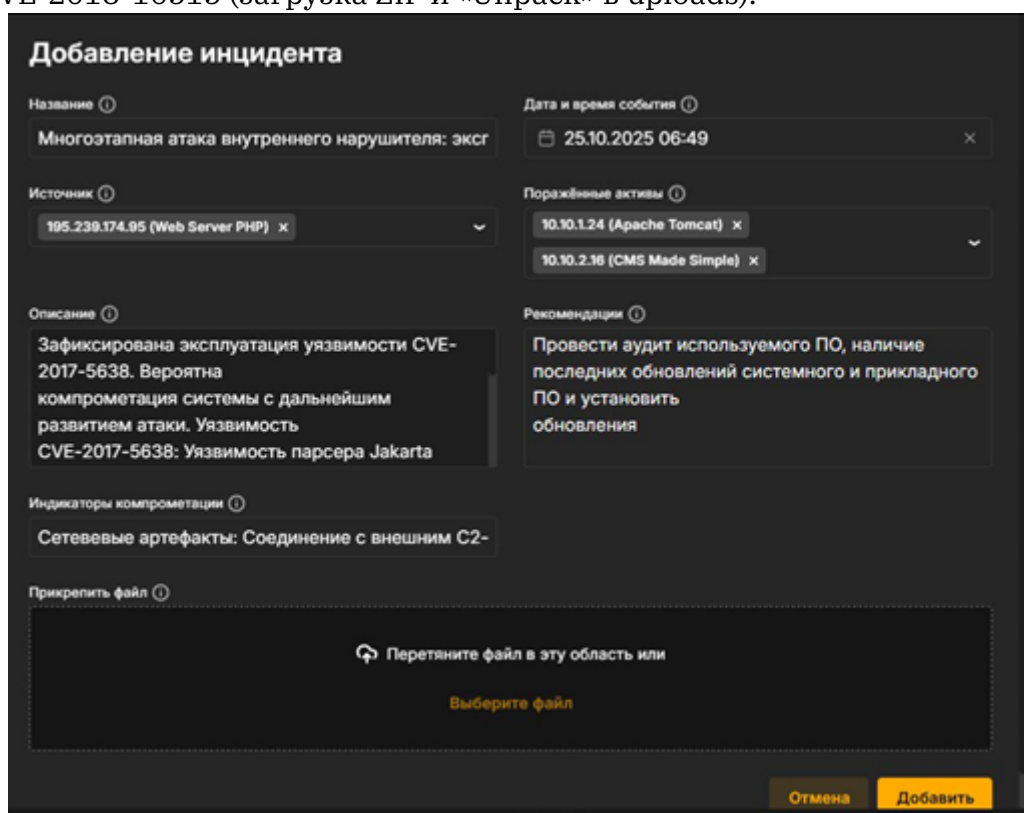


Рисунок 10 — CMS Made Simple → Site

Admin → Admin Log. События: неудачная авторизация admin, загрузка и распаковка knock.zip, вход пользователя user. Это согласуется с эксплуатацией CVE-2018-10515 (загрузка ZIP и «Unpack» в uploads).



Ри-

сунк 11 — Папка ...\\cmsms\\uploads\\: knock.php, knock.zip, htaccess.txt. Артефакты атаки присутствуют; подготовлен .htaccess для запрета выполнения.

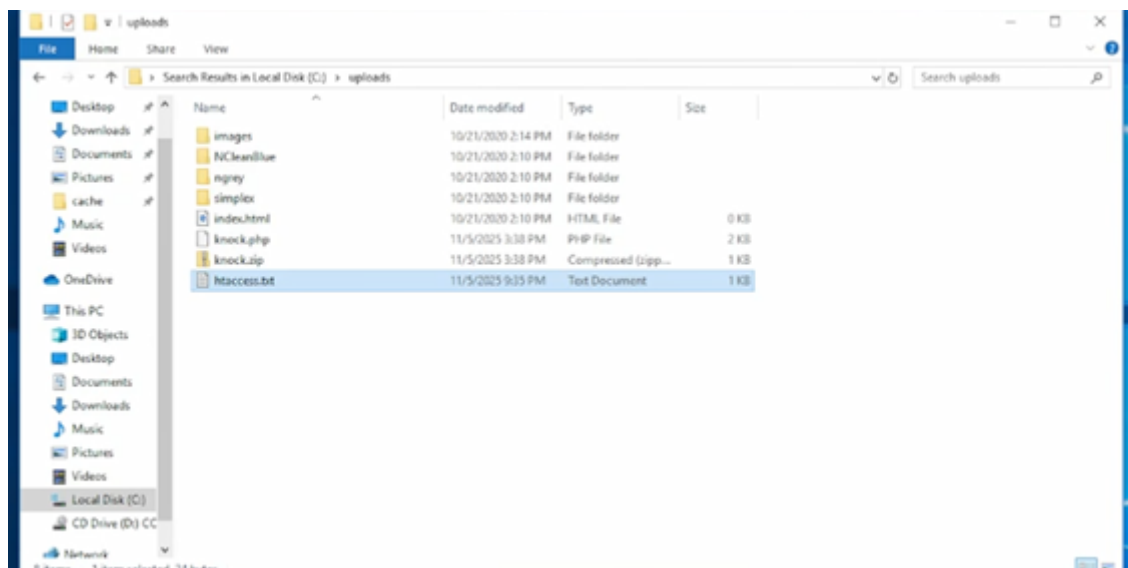


Рисунок 12 — Правило .htaccess: RedirectMatch 403 \.php\$ (блокировка исполнения PHP в uploads).



Рисунок 13

— netstat -bno: активные соединения. Зафиксированы PID/процессы (httpd.exe, winlogbeat.exe) и сессии к внешнему адресу 195.239.174.12:443 (IOC).

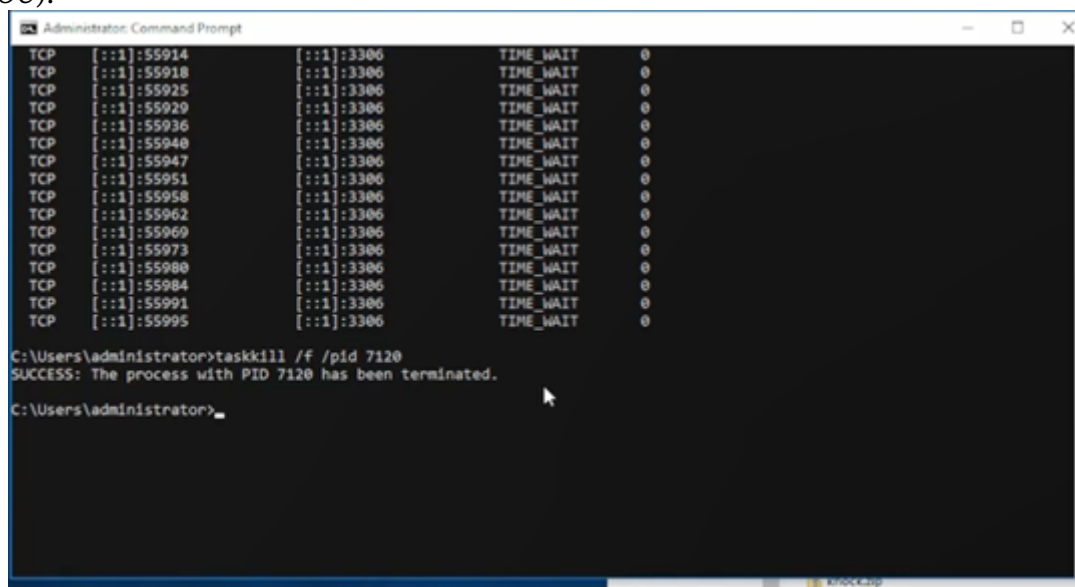


Рисунок 14 — Пресечение активности: `taskkill /f /pid 7120 SUCCESS`.

4.4 4. Устранение уязвимостей и укрепление

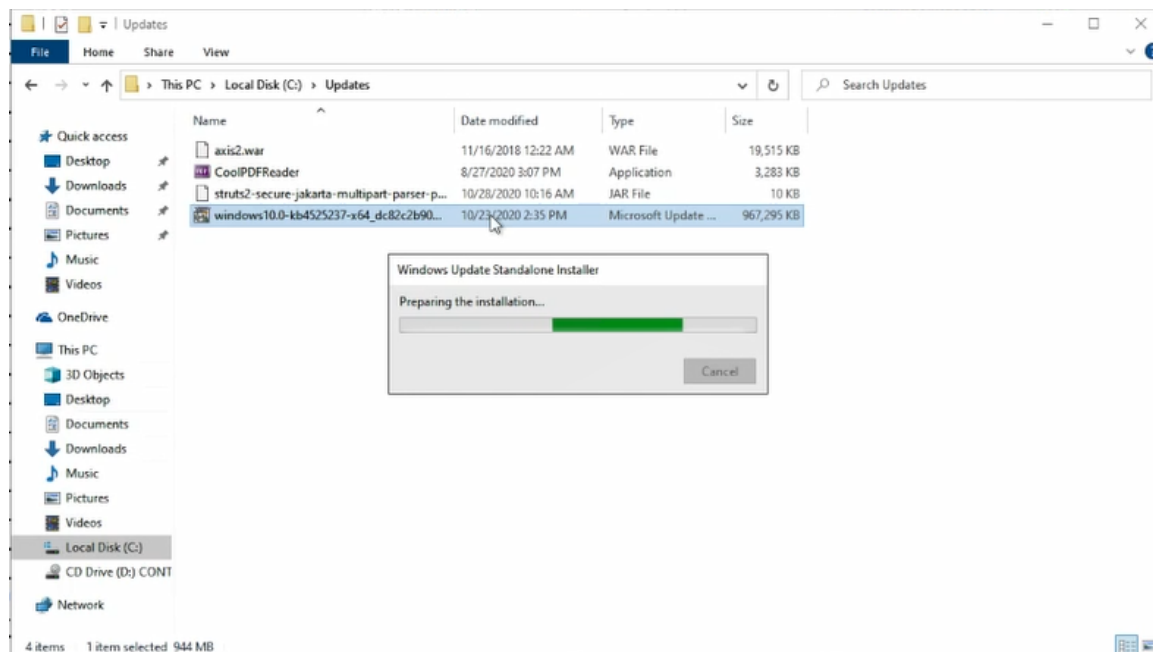


Рисунок 15 — Установка обновления Windows KB4525237 (Standalone Installer).

Закрывает известные LPE, использовавшиеся на этапе закрепления.

Добавление инцидента

Название

Многоэтапная атака внутреннего нарушителя

Дата и время события

05.11.2025 15:37

Источник

195.238.174.95 (Web Server PHP)

Поражённые активы

10.10.1.24 (Apache Tomcat)
10.10.2.36 (CMS Made Simple)

Описание

Зафиксирована эксплуатация уязвимости CVE-2017-5638. Вероятная компрометация системы с дальнейшим развитием атаки. Уязвимость CVE-2017-5638: Уязвимость парсера Jakarta

Рекомендации

Провести аудит используемого ПО, наличие последних обновлений системного и прикладного ПО и установить обновления

Индикаторы компрометации

шним C2-сервером, через зашифрованный туннель

Прикрепить файл

Перетяните файл в эту область или

Выберите файл

Отмена

Добавить

Рису-

нок 16 — Попытка SSH к 10.10.2.16:22 отклонена (Windows error 10061). SSH недоступен — внешняя поверхность уменьшена/сервис отключён или заблокирован.

Дополнительно (по методичке, без скриншотов в данном наборе): — отключён struts2-showcase в Tomcat Manager; — подключён Secure Jakarta Multipart parser (фикс CVE-2017-5638).

19

5 Выводы

Зафиксирована многоэтапная атака: эксплуатация CVE-2017-5638 на Tomcat с последующей компрометацией CMS Made Simple (загрузка и распаковка knock.zip → knock.php), получением высоких привилегий в Windows (4624/4672), созданием службы-закладки (7045) и сетевыми сессиями к внешнему C2. Меры реагирования: разрыв активной сессии (taskkill), блокировка выполнения скриптов в uploads через .htaccess, установка KB4525237, ограничение удалённого доступа (SSH), а также меры по Struts2 (отключение showcase, Secure Jakarta parser). Инцидент зарегистрирован и актуализирован в ViPNet TIAS.